

Table of Contents

Cisco Secure Workload — FIPS 140-2/3 Compliance Framework

Technical Runbook | Federal & Regulated Accounts

Version: 1.0 | **Standard:** FIPS 140-2 / FIPS 140-3 (CSW-Relevant Scope)

Reader's Guide

Who this is for. US federal agencies and federal contractors required to use FIPS-validated cryptographic modules, regulated industries with FIPS obligations (DoD supply chain, healthcare, some financial), and FIPS lab consultants advising them.

Read this first: CSW is **not itself a FIPS-validated cryptographic module**. It does not encrypt your data. CSW's role in a FIPS program is *enforcement and detection* — proving that your applications use only validated crypto and surfacing it when they don't. Read section 1 carefully before going further.

Questions this runbook helps you answer:

- *Where in my environment is non-FIPS cryptography still in active use today? (TLS 1.0/1.1, SSHv1, MD5-HMAC, RC4, custom protocols.)*
- *Can I detect at runtime when a service silently falls back to a non-validated algorithm — before an auditor or pen tester finds it?*
- *For my crypto boundary documentation, what process-level evidence supports the claim that "only the validated module is performing cryptographic operations"?*
- *During the FIPS 140-2 → 140-3 transition window, which workloads are still relying on now-deprecated 140-2 modules and represent procurement or audit exposure?*
- *What does CSW explicitly **not** cover, so I know what other controls I still need? (See section 6.)*

What you'll need. A list of systems with FIPS obligations (typically derived from contract or regulatory scope), your current cryptographic inventory (or willingness to discover one), and your crypto boundary documentation.

Where to start. Section 1 to set realistic expectations; sections 2–3 for what CSW actually does; section 4 if you're inside the 140-2 → 140-3 transition; sections 5–6 for evidence and explicit non-coverage.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-	Days 11–28

Phase	Goal	Key CSW actions	Typical duration
		owner signoff	
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Plaintext-protocol DENY policies with violation logs
- Programme-level crypto hygiene visibility (modules out of scope)
- 140-2 → 140-3 transition tracking on workload connections

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview & CSW Role

FIPS 140-2/3 is a US federal standard for cryptographic module validation. **CSW is not itself a cryptographic module** — it does not encrypt data at rest or in transit. However, CSW plays a critical **enforcement and detection** role in FIPS compliance programs by:

1. **Detecting non-FIPS-compliant cryptographic protocols** in workload communications
 2. **Enforcing FIPS-compliant communication paths** via micro-segmentation policy
 3. **Auditing all cryptographic service access** through flow and process telemetry
 4. **Identifying workloads using non-approved algorithms** through port/protocol analysis
-

2. FIPS-Relevant CSW Capabilities

2.1 Non-FIPS Protocol Detection

CSW ADM and flow telemetry identify the following non-FIPS-compliant communications:

Protocol / Service	Non-FIPS Indicator	CSW Detection Method
TLS 1.0 / 1.1	Non-approved TLS version	Port 443 flow + process context analysis
SSLv2 / SSLv3	Deprecated, non-FIPS	Flow telemetry protocol identification
MD5-based connections	Non-approved hash	Process + connection pattern analysis
Plain HTTP (port 80)	No encryption	Flow telemetry protocol filter
Plain FTP (port 21)	No encryption	Flow telemetry port filter
Telnet (port 23)	No encryption	Flow telemetry port filter
LDAP plain (port 389)	Non-encrypted directory	Flow telemetry port filter

Protocol / Service	Non-FIPS Indicator	CSW Detection Method
SNMPv1/v2 (port 161)	Non-encrypted management	Flow telemetry port filter

2.2 Enforcement of FIPS-Compliant Paths

CSW policy can **block non-compliant protocols** and **enforce approved alternatives**:

CSW Policy: FIPS-Protocol-Enforcement

```

DENY: Any → Any (port 80)      # Block plain HTTP
DENY: Any → Any (port 21)      # Block plain FTP
DENY: Any → Any (port 23)      # Block Telnet
DENY: Any → Any (port 389)     # Block plain LDAP
DENY: Any → Any (port 161)     # Block SNMPv1/v2

ALLOW: Any → Any (port 443)    # HTTPS (enforce TLS 1.2+ at app
level)
ALLOW: Any → Any (port 22)     # SSH (FIPS-compliant cipher suites)
ALLOW: Any → Any (port 636)    # LDAPS
ALLOW: Any → Any (port 162)    # SNMPv3
ALLOW: Any → Any (port 990)    # FTPS

```

2.3 Cryptographic Service Access Auditing

For workloads using FIPS-validated HSMs or crypto libraries:

CSW UI → Investigate → Flow Search

- Destination: HSM IP / crypto service endpoint
 - Process context: identifies which app is accessing crypto service
 - Log: full access audit for FIPS boundary documentation
-

3. FIPS Boundary Documentation

FIPS 140-2/3 requires precise definition of the cryptographic module boundary. CSW supports this through:

3.1 Crypto Service Scope

Define a CSW scope for FIPS-validated cryptographic infrastructure:

Root Scope

- └─ FIPS-Boundary
 - └─ HSM-Cluster (validated hardware)
 - └─ Crypto-Services (validated software libraries)
 - └─ Key-Management (KMS endpoints)

Policy for FIPS-Boundary scope:

- Default DENY all inbound

- ALLOW only explicitly approved workloads to access HSM/KMS
- LOG all connections to FIPS-Boundary scope (full audit trail)
- ALERT on any unapproved access attempt

3.2 Algorithm Identification via Process Telemetry

CSW process monitoring identifies workloads using non-FIPS-approved crypto libraries:

CSW UI → Investigate → Process Search

- Filter: process name contains "openssl", "libssl", "nss"
- Review: version number indicates FIPS-validated status
- Flag: workloads using pre-FIPS OpenSSL versions

4. FIPS 140-3 Transition Support

FIPS 140-3 (based on ISO/IEC 19790:2012) replaces 140-2. CSW supports the transition by:

- **Inventorying** all workloads accessing cryptographic services (ADM map)
- **Flagging** workloads still using FIPS 140-2-only validated modules
- **Tracking** rollout of FIPS 140-3 validated replacements via ADM comparison
- **Enforcing** updated protocol requirements as crypto standards evolve

5. Evidence Package for FIPS Compliance

Evidence Item	CSW Source	FIPS Relevance	Frequency
Non-FIPS protocol flow report	Investigate → Flow Search (port filter)	Module boundary	Weekly
FIPS-Boundary access log	Investigate → Flow Search (scope filter)	Access control	Continuous
Crypto service process audit	Investigate → Process Search	Module usage	Monthly
Policy enforcement log (FIPS policy)	Defend → Policy Analysis	Protocol enforcement	Monthly
HSM/KMS access audit	Flow Search → FIPS-Boundary scope	Key management	Continuous

6. What CSW Does NOT Cover

FIPS Requirement	Outside CSW Scope	Recommended Solution
Cryptographic module validation	CSW is not a crypto module	Use FIPS 140-3 validated libraries (OpenSSL FIPS, BouncyCastle)
Algorithm implementation testing	Hardware/software crypto validation	NIST CMVP testing laboratory
Key generation & storage	Key lifecycle management	FIPS-validated HSM (Thales, Entrust)
Self-tests at module boundary	Module-level testing	Crypto library self-test procedures

Related Frameworks

- [NIST SP 800-53 Rev 5](#) — SC-13 and the broader cryptographic-control family that requires FIPS-validated modules.
- [NIST SP 800-207](#) — Tenet 4 (encryption regardless of network location) sits on the same crypto foundation.
- [ISO/IEC 27001:2022](#) — Annex A.8.24 cryptographic controls map to FIPS-validated module use.

Replace [Customer Name] and bracketed fields before customer delivery.